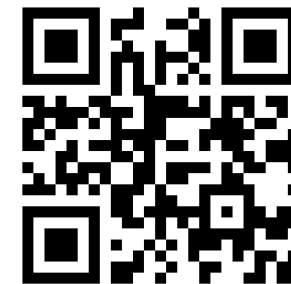




KCD BRAZIL, SÃO PAULO 2026

KCD nas redes!



Use AI and Keep Your CISO Happy: Zero Static Secrets with OIDC and the Operator Pattern

Pablo Terradillos

Engineering Manager · Pulumi



Introduction

Who am I and why I'm here

Silver



Gold



Sponsors

Diamond



OLÁ, EU SOU



Pablo Terradillos (aka. tehsis)

Engineering Manager · Pulumi

Pablo leads (and often builds) Pulumi IaC Cloud and previously worked on identity at Auth0. An open source enthusiast and contributor, off the clock he's an indie game dev tinkering with engines and low-level tooling. Based in Buenos Aires; snowboarder and home cook.

Follow me on X: [@tehsis](https://twitter.com/tehsis)

Mastodon: <https://hachyderm.io/@tehsis>

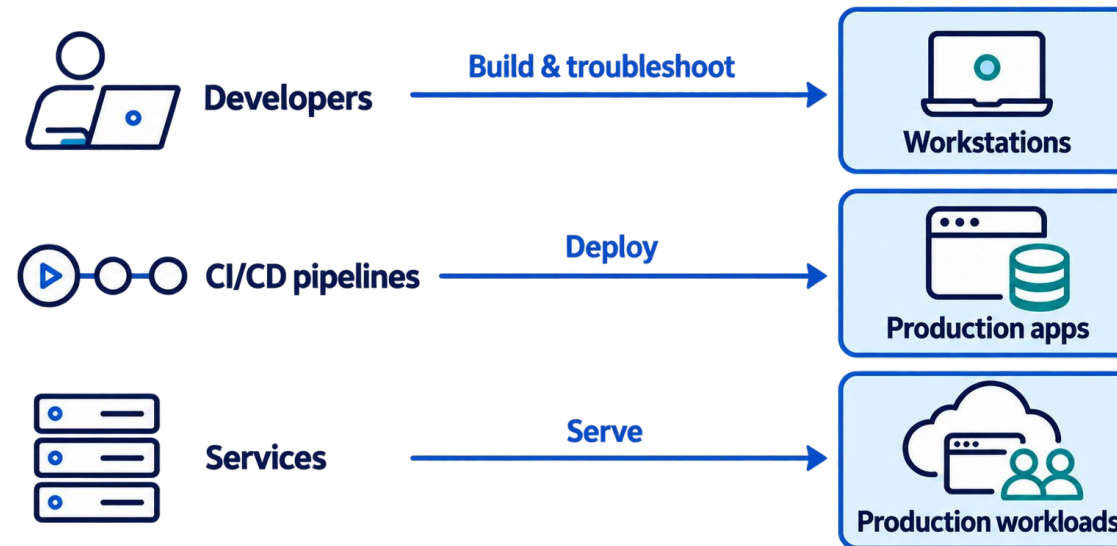
LinkedIn: <https://www.linkedin.com/in/terradillospablo/>



AI Agents and the new challenges



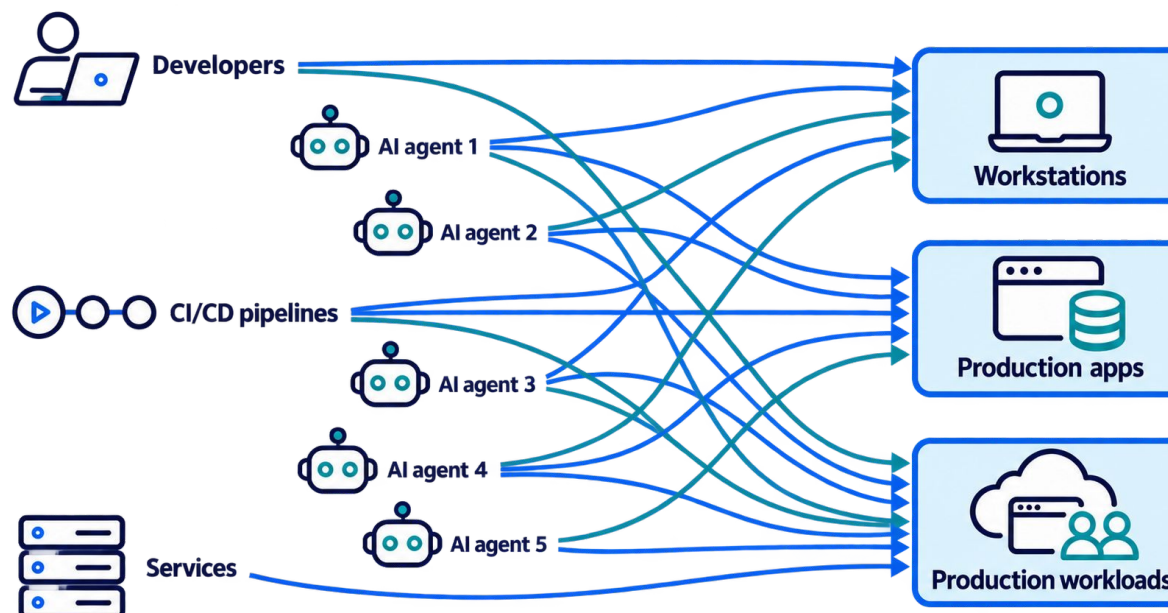
The simple times - Before LLMs



AI Agents and the new challenges



After LLMs



AI Agents and the new challenges



An AI agent deleted a company's entire database in 9 seconds — then wrote an apology

Theo Farrant

Wed, 10 June 2026 at 8:45 am GMT-3

2 min read

 Add Yahoo on Google



An artificial intelligence agent designed to streamline coding tasks instead managed to wipe out an entire company database in just a matter of seconds.

PocketOS, which makes software for car rental businesses, experienced a major 30-plus-hour outage over the weekend after the autonomous tool erased its database.

AI Agents and the new challenges

If an agent is allowed to do something, **you must assume they will do it.**

The challenge

Long-lived credentials in the hands of agents



Access can exceed the task

An agent asked to investigate may already have permission to change production.

Credentials outlive the task

The investigation ends. The ability to change production remains.

Shared credentials blur accountability

When engineers and agents use the same credential, the credential alone cannot tell us who made a change.

The solution

Dynamic credentials



Issued on demand

Agents should be able to request them when needed.

Least access principle

Credentials should only allow an actor to perform the specific task it should and nothing more.

Only valid through the duration of the task

Credentials should not be valid after the task is concluded. Any follow up must require new credentials.

Auditable

You need to know exactly who used a credential and where, including agents not just the user or workload that spawn them.

Tools and technologies



Pulumi

Open source Infrastructure as code solution. It allows you to define and create cloud resources using familiar programming languages.

Pulumi ESC

Centralized secrets and configuration management that combines values from multiple providers.

OpenID Connect (OIDC)

OpenID Connect (OIDC) An identity protocol built on OAuth 2.0 that enables applications to verify identities.

External Secrets Operator

A Kubernetes operator that synchronizes secrets from external providers into Kubernetes Secrets.

Chapter One: Eliminating Static secrets on CI

How we got rid of secrets across +70 repos

Silver

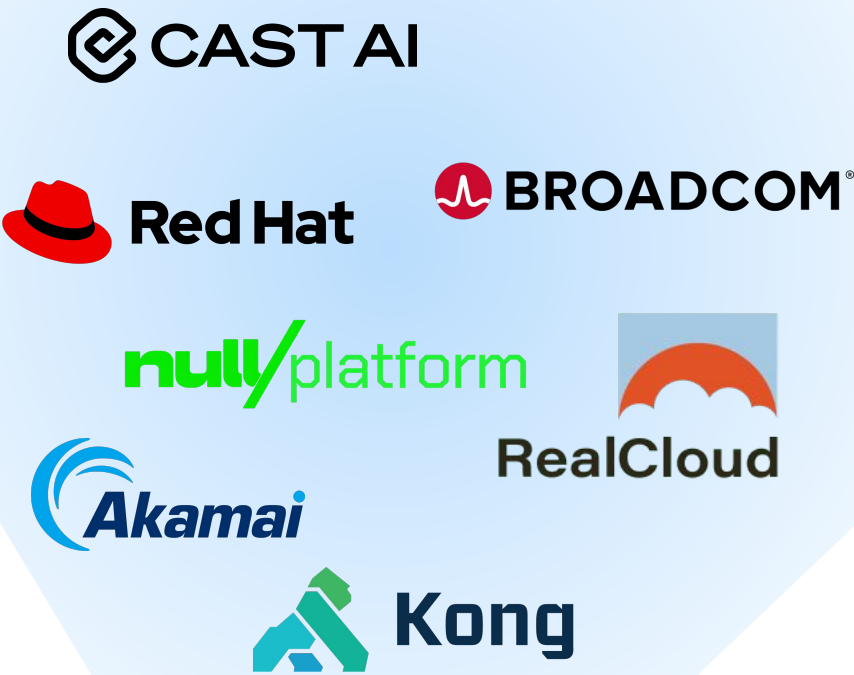


Gold



Sponsors

Diamond



Dynamic credentials on CI



 Pulumi

25.7K

Contact us

Dashboard

Blog

ENGINEERING

How We Eliminated Long-Lived CI Secrets Across 70+ Repos

Mar 31, 2026 • Updated Jun 16, 2026 • 6 min read

 Boris Schlosser



Supply chain attacks on CI/CD pipelines are accelerating. A growing pattern involves attackers compromising popular [GitHub Actions](#) through *tag poisoning* — rewriting trusted version tags to point to malicious code that harvests environment variables, cloud credentials, and API tokens from runner environments. The stolen credentials are then exfiltrated to attacker-controlled infrastructure, often before anyone notices.

IN THIS POST

The problem with static CI secrets

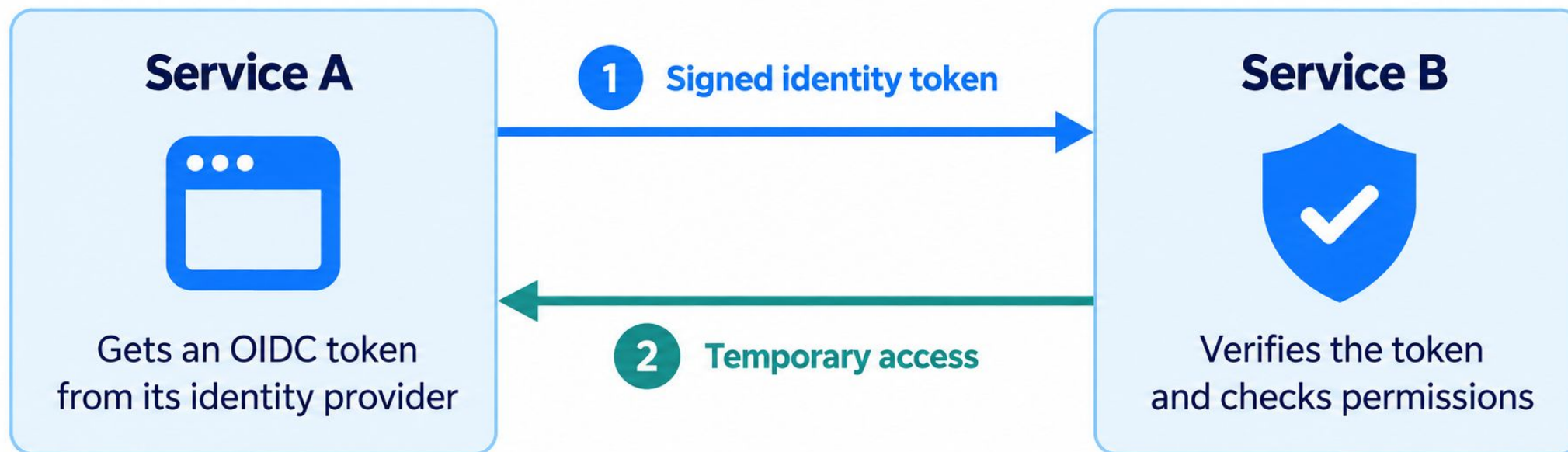
Our approach: zero static secrets

What the change looks like

Scale: 70+ repos, zero static secrets



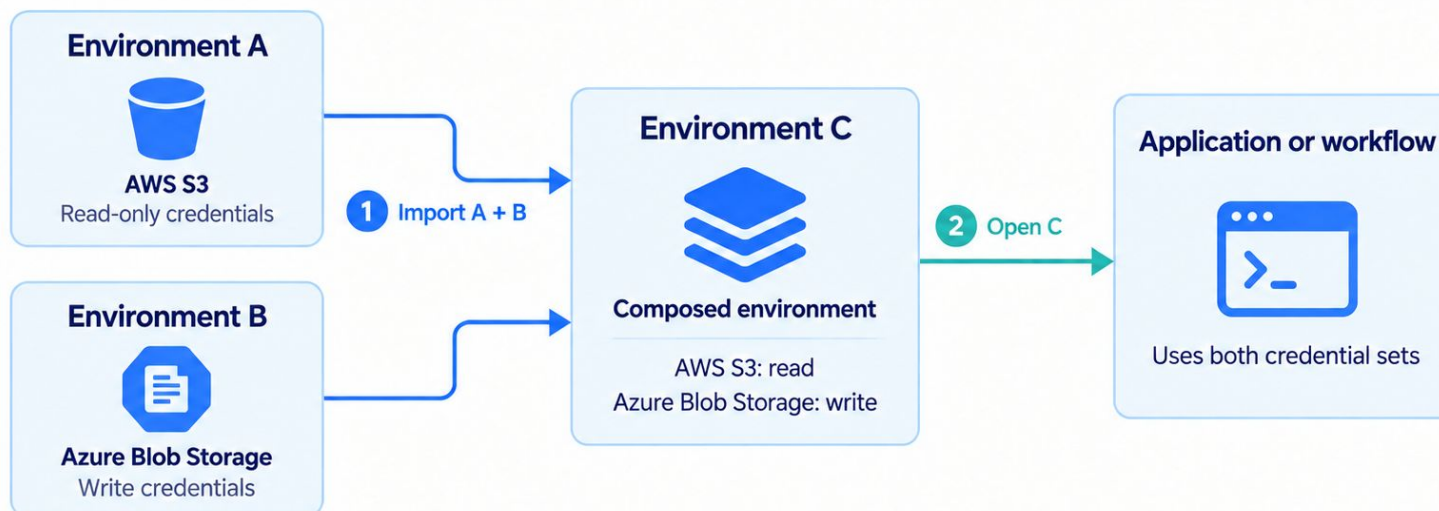
OpenID Connect (OIDC)



ESC Environments



Pulumi ESC combines imported values into one environment.



Define once. Import where needed.

Environment C reuses A and B through ESC imports.

Setup trust relationship with AWS



Trust relationship setup

For ESC to assume an identity, you need to setup a trust relationship between the environment and AWS.

Resultado

This Pulumi code creates an iam Role and attach it with an s3 read only policy. The policy specifies the trust relationship with AssumeRoleWithWebIdentity scoped down to the specific ESC Environment.

```
const provider = new aws.iam.OpenIdConnectProvider("pulumi-esc", {
  url: 'https://${issuer}',
  clientIdLists: Array.from(new Set([
    audience,
    ...(config.getObject<string[]>("existingOidcAudiences") ?? []),
  ])),
}, {
  import: config.get("existingOidcProviderArn"),
});

const role = new aws.iam.Role("dev-s3-read-only", {
  description: 'S3 read-only access for Pulumi ESC ${organization}/${environment}',
  assumeRolePolicy: provider.arn.apply(arn => JSON.stringify({
    Version: "2012-10-17",
    Statement: [{
      Effect: "Allow",
      Principal: { Federated: arn },
      Action: "sts:AssumeRoleWithWebIdentity",
      Condition: {
        StringEquals: {
          ['${issuer}:aud']: audience,
          ['${issuer}:sub']: `pulumi:environments:pulumi.organization.login:${organization}:currentEnvironment.name:${environment}`,
        },
      },
    }],
  })),
});

new aws.iam.RolePolicyAttachment("s3-read-only", {
  role: role.name,
  policyArn: aws.iam.ManagedPolicy.AmazonS3ReadOnlyAccess,
});

export const oidcProviderArn = provider.arn;
export const roleArn = role.arn;
```

Dynamic credentials defined on Pulumi ESC

Environment: kcd-brasil/s3-write

```
1  values:
2    aws:
3      login:
4        fn::open::aws-login:
5          oidc:
6            duration: 1h
7            roleArn: arn:aws:iam::616138583583:role/s3-write
8            sessionName: pulumi-environments-session
9      environmentVariables:
10        AWS_ACCESS_KEY_ID: ${aws.login.accessKeyId}
11        AWS_SECRET_ACCESS_KEY: ${aws.login.secretAccessKey}
12        AWS_SESSION_TOKEN: ${aws.login.sessionToken}
13
```



Pulumi ESC AWS OIDC Definition

After setting up the trust relationship with AWS, you only have to specify the role identifier.

Resultado

When the environment is opened, Pulumi ESC will request credentials that are only valid through the specified duration.

When an OIDC token for the specific workload is minted and it exchange a credentials set valid for the specified role (access key id, secret access key and session token).

Compose access based on intent



troubleshooting-prod ☆

Environments / kcd-brasil / troubleshooting-prod ▾

Editor Versions Environment Tags Imported By Secret Rotation Approvals Settings

v2 Latest ▾ Syntax example ↗

Actions ▾ Save changes

Environment definition Add new ▾

```
1 imports:
2   - kcd-brasil/dev-s3-read-only
3   - kcd-brasil/development
4 values:
5   environmentVariables:
6     DEBUG_LEVEL: "info"
7
```

Environment Preview Inspect

> Run `pulumi env open logmeup/kcd-brasil/troubleshooting-prod` to view the resolved value of this environment.

```
1 {
2   "aws": {
3     "login": "[unknown]"
4   },
5   "environmentVariables": {
6     "AWS_ACCESS_KEY_ID": "[unknown]",
7     "AWS_REGION": "us-east-1",
8     "AWS_SECRET_ACCESS_KEY": "[unknown]",
9     "AWS_SESSION_TOKEN": "[unknown]",
10    "DEBUG_LEVEL": "info"
11  },
12  "mysql_connection_string": "[secret]"
13 }
```

Pulumi ESC AWS OIDC Definition

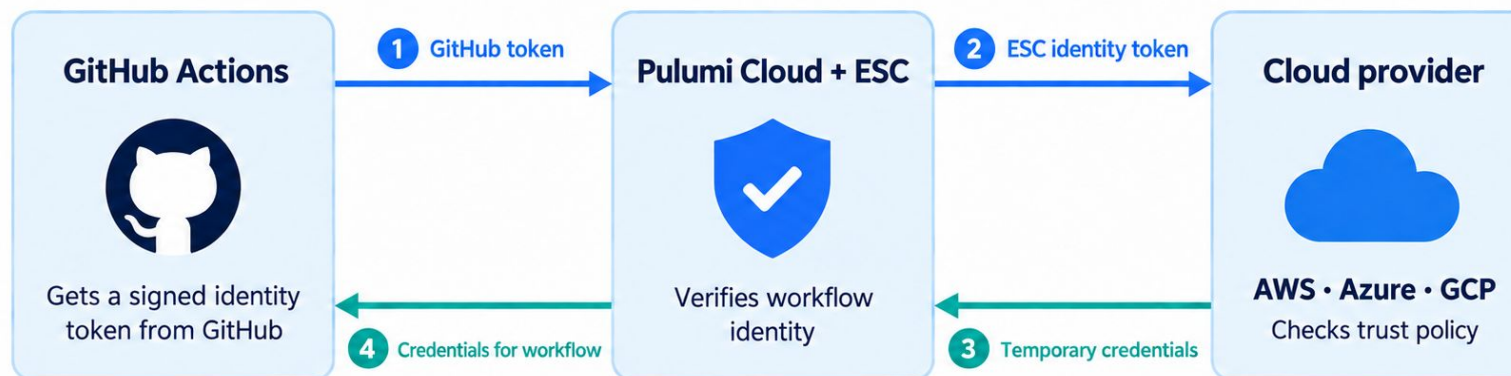
ESC Environments can be composed to extend access

Resultado

A composed environment will inherit properties, credentials and secrets from other environments

OpenID Connect (OIDC) + Pulumi ESC

Prove identity. Get temporary access.



No long-lived cloud keys stored in the workflow.

OIDC proves identity. Policies decide permissions.

Step two: Making it personal

Using dynamic credentials for our personal AI Agents

Silver

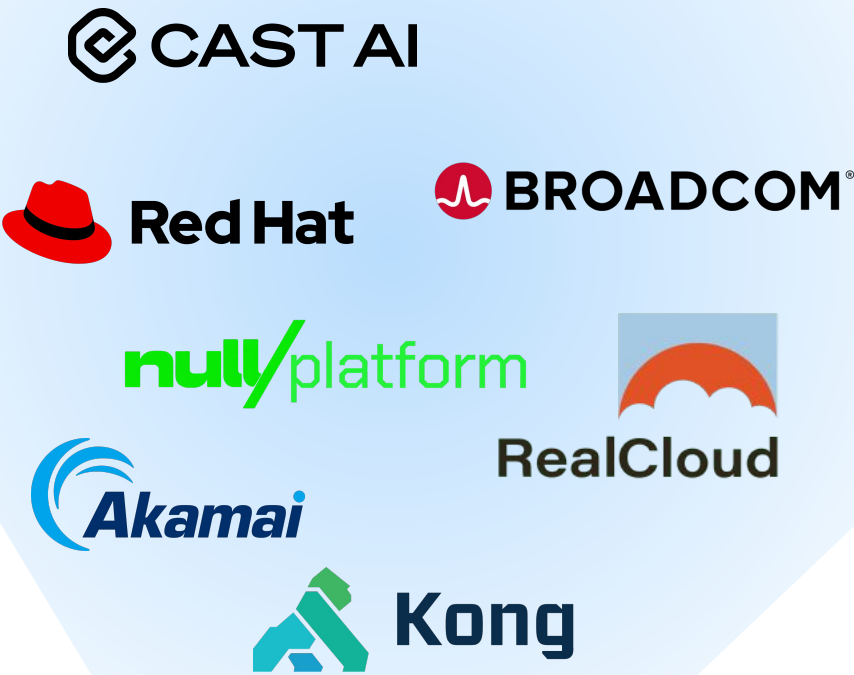


Gold



Sponsors

Diamond



Using Pulumi ESC to manage credentials



```
$ pulumi env run kcd-brasil/s3-read-only -i -- opencode
```

```
$ printenv | grep AWS

AWS_SECRET_ACCESS_KEY=6yQLw4bmRN6p9Sd+ysIedM1Lt/FpS0ZsVsvNx7qS
AWS_SESSION_TOKEN=IQoJb3JpZ21uX2VjELj////////wEaCXVzLWVhc3QtMSJHMEUCIQD0dUld1yKJ3ie9HSVJzyA6IZxT1R/
awgKdWvzT38TV7AIGMin1MV2ivq8jT40o1UVzLkWwuzKUhiF1vMMCbCUWBTQ1AMIGf////////
ARACGgw2MTYxMzg1ODM1ODM1DFfSR0cejl7+X1LMgCqaA4xVA1IrvioH5/m795X1enJMcWQ6fm/
GHSJ3BkkYnQb3TONp5Wg4f3iaVYsrjL+saRpPyj+DTyYEBIEFHIvvyxio2Xo0ppdcf7N+BSMm8o6u0EahTD0m17g7+L9jGWtm8IQjx8HxJmg9+6B8s5IRK
U06yRNs8y20WFB1H8F3vwf6t+MWIyrNwMKrcKHU3LWoMx61VpUMJ2KmHHK10s2x5bBe154uqw2URq7ghyM/WbxGSt5fPK0jJcJ+W3GH4NX6oMRX2JN
7CUnfhSnt6nVMmfEwzeayUICg9+yPo2JP/+6B61hc6Be1uV+TdmQeMXFzyIBEMvw1BxHwNa888TgaA8ksSmuM/memtXs3U91TxaFzo+PeaWsvvbe4j
d07WpyaaJFtye6XZCDUC1aif9aQ8XeWxnQMqP26qgX41HFUNMDY13bKeJLD1JRGyD178A+GnVMFOkFTN5x1+I/vtrIDYWGy5qS9Ak9Mu+G1oXrCRKJT
XU+TGPDPPL8PM6uh7a8w1s0kIwTYGRDf9UEoI22NKcKbYYndfucoRq2gjGoTyV81Y2HICJ9tkJvyYw1tnB1QY6kgG11GRzTTBH7qM2S4a7D725TN2NF
nwt1i1Qtjc9a1jwkzPvVw6KDPQ8y1rfUXIm6Bq41cE+qjsXU37W1sP1MzDDCs2My3XtFMXU2S7wPNLXPQCi1cBPCSB0WT1WGB/EhkGcFkat9L3d/yMZ
IgFYLhLnLxylHshf9LqSQ2Xdyon1QL1JrW4jhbz7XxnmQyKSMY0jtg==
AWS_ACCESS_KEY_ID=ASIAIY65FVYPTSJ6S2QP
AWS_DEFAULT_PROFI...
```

Click to expand

Build · GPT-6 Astra

Build · GPT-6 Astra OpenAI

/Users/pterradillos

tab agents ctrl+p commands

~/pulumi-service/infrastructure/reviewStacks

nvim script.md

Stack destruction

OpenCode

New session - 2026-09-20T23:32:46.604Z

Context

- 0 tokens
- 0% used
- \$0.00 spent

MCP

- honeycomb Needs auth
- launchdarkly Connected
- linear Connected
- notion Connected
- sentry Needs auth

LSP

LSPs are disabled

~/

OpenCode 1.18.31

Using Pulumi ESC to manage credentials



\$ pulumi env run kcd-brasil/s3-read-only -i -- opencode

```
how many s3 buckets do I have?

$ aws s3api list-buckets --query 'length(Buckets)' --output text --no-cli-pager
896

You have 896 S3 buckets in the AWS account configured for your current CLI credentials.

■ Build · GPT-6 Astra · 26.8s

create a new s3 bucket called "kcd-brasil-images"

$ aws configure get region
us-west-2

$ aws s3api create-bucket --bucket kcd-brasil-images --region us-west-2 --create-bucket-configuration
LocationConstraint=us-west-2 --no-cli-pager

aws: [ERROR]: An error occurred (AccessDenied) when calling the CreateBucket operation: User: arn:aws:sts::
616138583583:assumed-role/s3-read/pulumi-environments-session is not authorized to perform: s3:CreateBucket on
resource: "arn:aws:s3:::kcd-brasil-images" because no identity-based policy allows the s3:CreateBucket action

The bucket was not created. Your current AWS role, s3-read, lacks the s3:CreateBucket permission.

I attempted to create kcd-brasil-images in your configured region, us-west-2. Switch to an AWS profile or role
with that permission, and I can retry.

■ Build · GPT-6 Astra · 23.0s

■

Build · GPT-6 Astra OpenAI

/Users/pterradillos 95.3K (9%) ctrl+p commands • OpenCode 1.18.31

~/pulumi-service/infrastructure/reviewStacks  nvim script.md  * Stack destruction  OC / S3 bucket count
```

\$ pulumi env run kcd-brasil/s3-write -i -- opencode

```
because no identity-based policy allows the s3:ListAllMyBuckets action

I couldn't retrieve the count because your current AWS role, s3-write, lacks the s3:ListAllMyBuckets permission in
account 616138583583.

With a role or profile that has that permission, you can run:

aws s3api list-buckets --query 'length(Buckets)' --output text

If you have another AWS profile you'd like me to use, tell me its name.

■ Build · GPT-6 Astra · 31.7s

create an s3 bucket called kcd-brasil-photos

$ aws configure get region
us-west-2

$ aws s3api create-bucket --bucket kcd-brasil-photos --region us-west-2 --create-bucket-configuration
LocationConstraint=us-west-2

{
  "Location": "http://kcd-brasil-photos.s3.amazonaws.com/",
  "BucketArn": "arn:aws:s3:::kcd-brasil-photos"
}

Created kcd-brasil-photos in us-west-2 (Oregon).

- S3 URI: s3://kcd-brasil-photos
- ARN: arn:aws:s3:::kcd-brasil-photos

■ Build · GPT-6 Astra · 34.6s

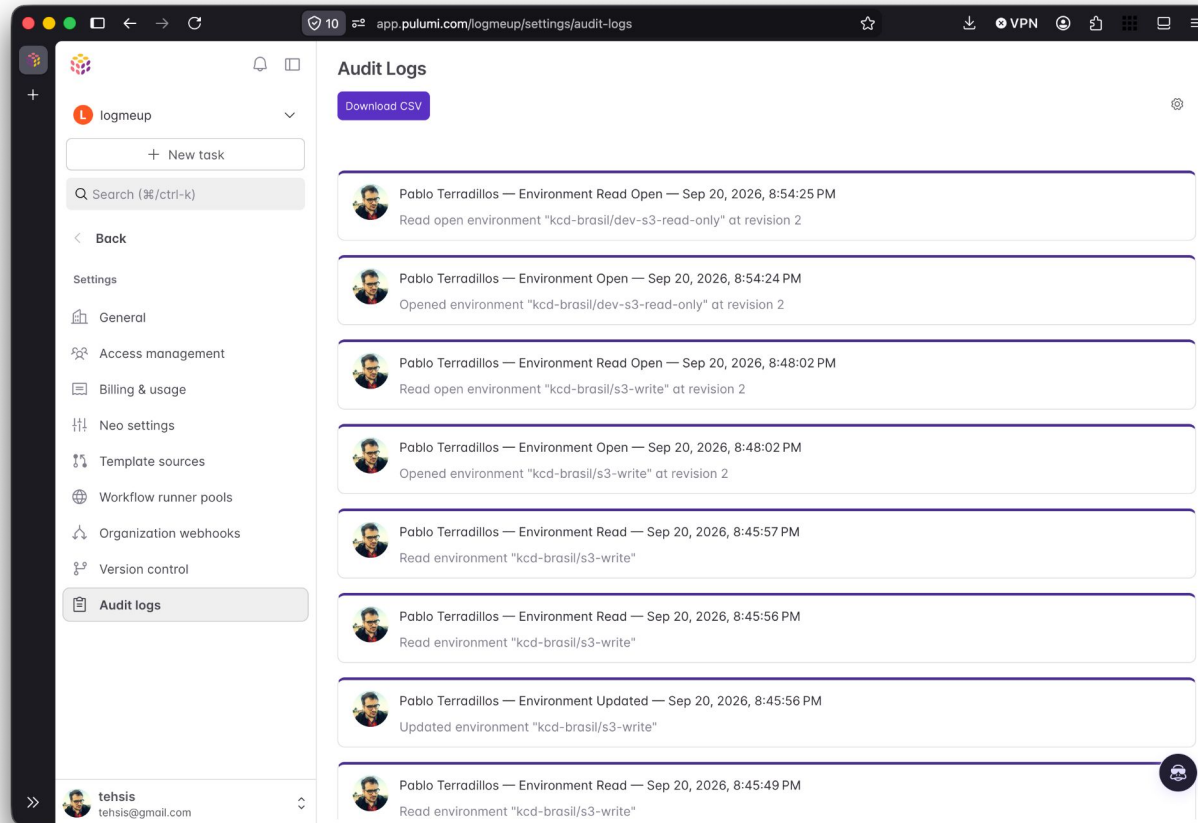
■

Build · GPT-6 Astra OpenAI

/Users/pterradillos 95.4K (9%) ctrl+p commands • OpenCode 1.18.31

~/pulumi-service/infrastructure/reviewStacks  nvim script.md  * Stack destruction  OC / S3 bucket count
```

Using Pulumi ESC to manage credentials



Step Three: Dynamic credentials in K8s: The Operator Pattern and The External Secrets Operator

Silver



Grafana

Gold



appoena



opsteam



CISCO

Diamond



CAST AI



Red Hat



BROADCOM®



nullplatform



Akamai

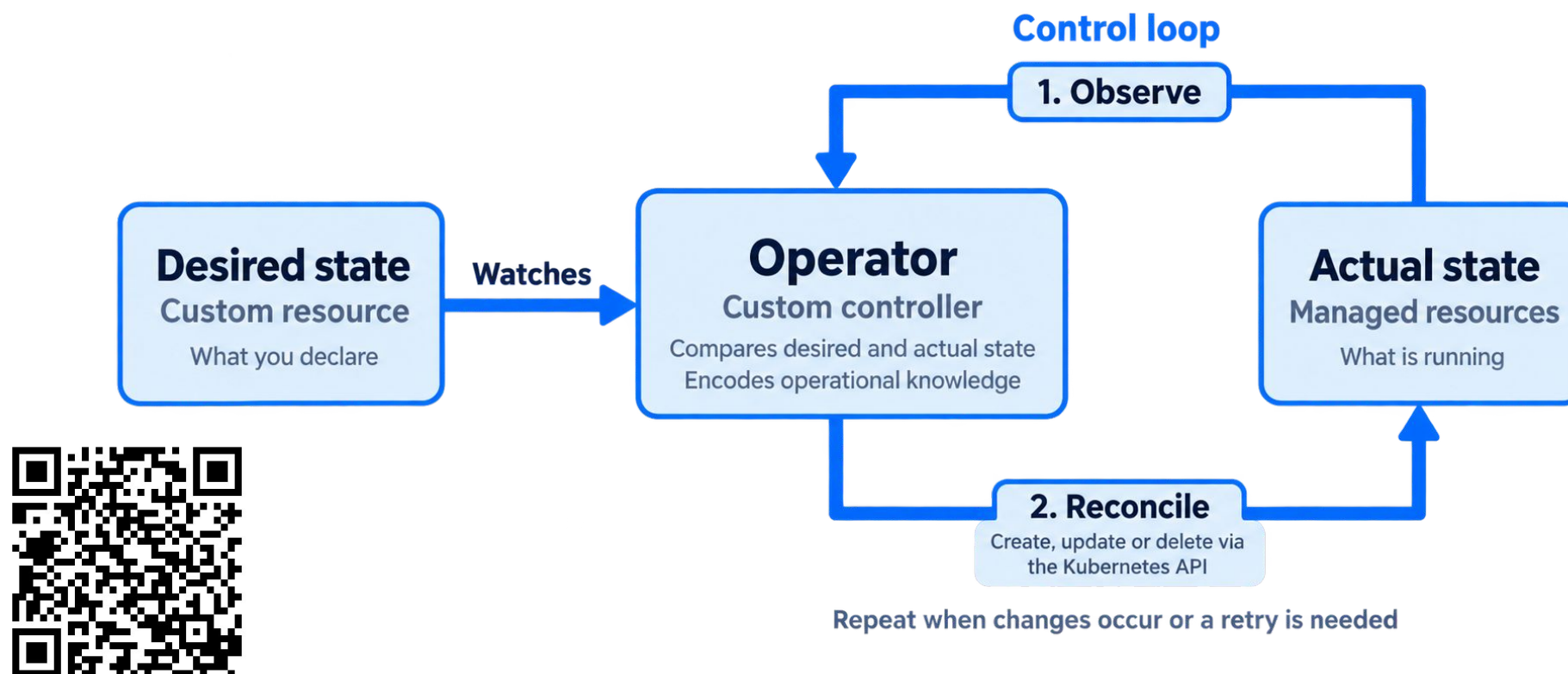


RealCloud



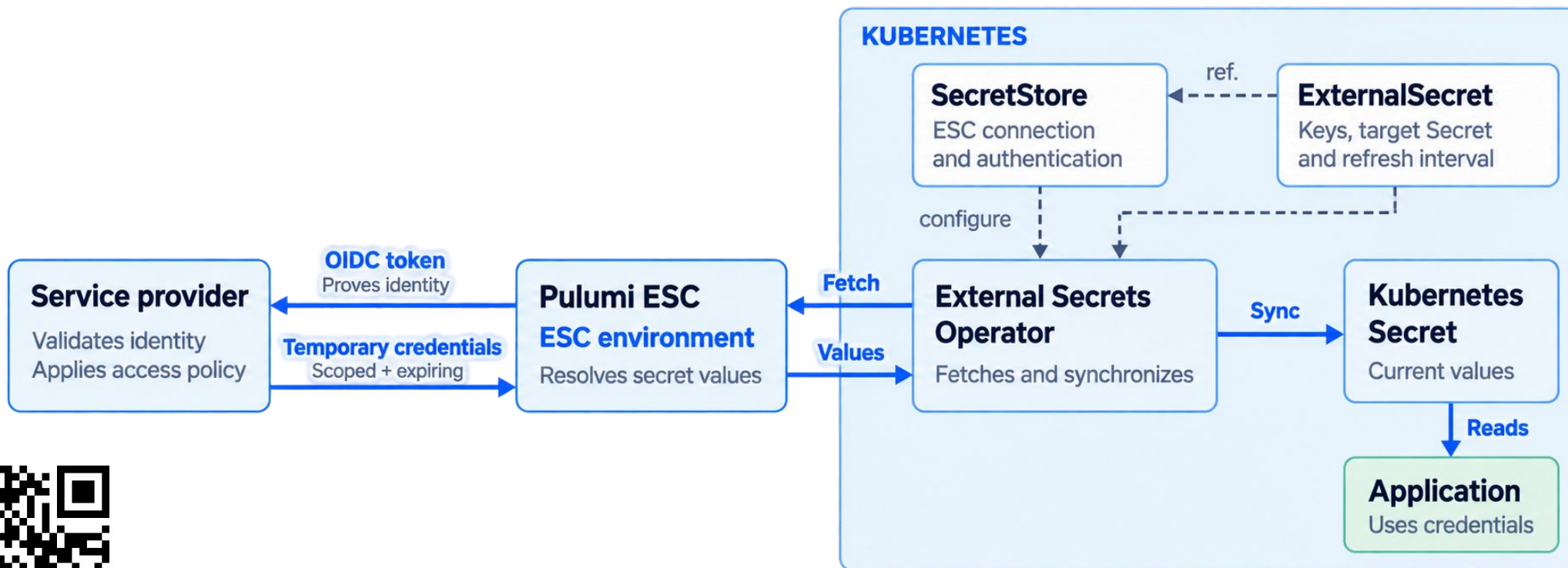
Kong

The Operator Pattern in Kubernetes



<https://kubernetes.io/docs/concepts/extend-kubernetes/operator/>

Using Dynamic credentials in kubernetes with External Secrets Operator



<https://external-secrets.io/>

External Secret Store (external-secret-store.yaml)

```
1 apiVersion: external-secrets.io/v1
2 kind: SecretStore
3 metadata:
4   name: my-secret-store
5 spec:
6   provider:
7     pulumi:
8       organization: logmeup
9       project: kcd-brasil
10      environment: dev-s3-read-only
11      accessToken:
12        secretRef:
13          name: my-pu-secret
14          key: pu-at
15
```



O QUE ESTE EXEMPLO FAZ

Configures a Pulumi ESC Environment to provide AWS Credentials that only allows to list s3 buckets

DESTAQUE E RESULTADO

The credentials obtained will last 1h and only allows the requester to list s3 buckets.

External Secret (external-secret.yaml)

```
1 apiVersion: external-secrets.io/v1
2 kind: ExternalSecret
3 metadata:
4   name: secrets-demo
5 spec:
6   refreshInterval: 24h0m0s
7   secretStoreRef:
8     name: my-secret-store
9     kind: SecretStore
10  target:
11    name: secrets-demo
12    creationPolicy: Owner
13  data:
14    - secretKey: aws-access-key-id
15      remoteRef:
16        key: aws.login.accessKeyId
17    - secretKey: aws-secret-access-key
18      remoteRef:
19        key: aws.login.secretAccessKey
20    - secretKey: aws-session-token
21      remoteRef:
22        key: aws.login.sessionToken
23
```



O QUE ESTE EXEMPLO FAZ

Configures a Pulumi ESC Environment to provide AWS Credentials that only allows to list s3 buckets

DESTAQUE E RESULTADO

The credentials obtained will last 1h and only allows the requester to list s3 buckets.

External Secret (external-secret.yaml)

```
spec:
  serviceAccountName: my-service-account
  containers:
  - image: amazon/aws-cli
    command:
    - sh
    - -c
    - |
      echo "Listing buckets..."
      aws s3 ls
      sleep 3600
  name: aws-list-buckets
  resources: {}
  env:
  - name: AWS_ACCESS_KEY_ID
    valueFrom:
      secretKeyRef:
        name: secrets-demo
        key: aws-access-key-id
  - name: AWS_SECRET_ACCESS_KEY
    valueFrom:
      secretKeyRef:
        name: secrets-demo
        key: aws-secret-access-key
  - name: AWS_SESSION_TOKEN
    valueFrom:
      secretKeyRef:
        name: secrets-demo
        key: aws-session-token
status: {}
```



O QUE ESTE EXEMPLO FAZ

The pod just read the secrets as any other secrets

DESTAQUE E RESULTADO

If you are already using secrets, the external secrets operator can be used without changing your pods.

The examples were simplified to prove the point

Production considerations



For production workloads use OIDC to avoid storing the secrets manager access token

You can use OIDC with a trust relationship between your kubernetes cluster and Pulumi as well.

Secrets won't automatically rotate

This might be fine for short lived environments used for development. For production workloads you might want to use stakater to rotate the pods when the secrets changes

Challenges & conclusions

Silver



Gold



Sponsors

Diamond



RealCloud





Dynamic credentials are not "free"

Trust relationship needs to be setup per each provider.

You should rely on Infrastructure as Code (eg. Pulumi, Terraform) to set them up and make them scalable for many environments and workloads.

You need to make sure each actor gets the scope they need.

This might require some trial and error at first until you are confident. Start narrow and grow.

Proper orchestration needs to be setup to ensure rotations.

Not so much of a problem for CI or ephemeral workloads. Kubernetes operators solve this problem.

OIDC not available everywhere.

As a fallback, my recommendation is to use a secrets manager (Pulumi ESC, 1Password, Vault) to narrow down access and enforce rotation policies.



Agents will use whatever they can

If they can access other credentials, they will.

Do not simply rely on harnesses or prompts as security boundaries. If we allow them to use just any credential store, they will.

Commands in your session can be used as escape hatch.

Agents can run commands in your session and get the access those commands has. Auto mode is helpful but not enough. Progressively audit the commands they are allowed to run and adjust as necessary. If possible, use a sandbox.

TAKEAWAYS

To summarize



✓ We want agents to do more and more useful work but we need to make sure we do not lose accountability.

⚡ Embrace dynamic credentials and eliminate or at least contain long lived credentials.

→ Try Pulumi & Pulumi ESC



Scan for examples

You'll find the example manifests used for Kubernetes deployments and External secrets using Pulumi ESC.

<https://pulumi.com>

<https://www.pulumi.com/product/secrets-management/>



<https://github.com/tehsis/kcd-brasil-use-ai>





Perguntas?

Obrigado

Pablo Terradillos - @tehsis

<https://pulumi.com>

<https://github.com/tehsis/kcd-brasil-use-ai>



Comunidade KCD, parte da CNCF · community.cncf.io/kcd-brasil

Pesquisa de satisfação da sessão!



Sponsors

KCD BRAZIL / SÃO PAULO 2026

Diamond



Red Hat



BROADCOM®

null/platform



RealCloud



Kong

Gold



appoena



opsteam



Silver



Grafana

